

Penetration Testing Report

Exploitation & Web Application Security Testing

PREPARED BY

Nithin Vignesh

TARGET URL

http://localhost:3100

TOOLS USED

Browser, Burp Suite, Gobuster

TARGET APPLICATION

OWASP Juice Shop (Local Training Instance)

ENGAGEMENT SCOPE

Local intentionally-vulnerable application

CLASSIFICATION

Confidential

1. Test Environment

Target	OWASP Juice Shop — local training environment
Target URL	http://localhost:3100
Kali Access URL	http://192.168.56.1:3100
Tools	Browser, Burp Suite, Gobuster
Scope	Local, intentionally vulnerable application

2. Executive Summary

This report documents exploitation and web application security testing performed against a local OWASP Juice Shop training environment. The assessment covered SQL injection authentication bypass, DOM-based cross-site scripting, discovery of the administration endpoint, HTTP request interception using Burp Suite, and modification of an HTTP request parameter. All testing was conducted strictly within the authorized local lab scope.

HIGH × 2

MEDIUM × 2

INFO × 1

3. Findings Summary

ID	Finding / Test	Severity	Outcome
PT-01	SQL Injection — Login Bypass	HIGH	Successfully demonstrated
PT-02	DOM-Based Cross-Site Scripting (XSS)	HIGH	Successfully demonstrated
PT-03	Hidden Administration Panel Exposure	MEDIUM	Successfully discovered / accessed
PT-04	Burp Suite HTTP Request Interception	INFO	Successfully demonstrated
PT-05	HTTP Parameter Modification	MEDIUM	Successfully demonstrated

Findings are ordered by discovery sequence, not severity. See individual write-ups below for full detail.

4. Detailed Findings

PT-01 — SQL Injection — Login Bypass

HIGH

CWE-89: SQL Injection

EXPLOITATION STEPS

SQL injection was tested in the login form using the payload ' OR 1=1-- with a test password. The application accepted the crafted input and the administrator login challenge was successfully solved.

```
' OR 1=1--
```

IMPACT

Successful SQL injection can bypass authentication entirely and provide an attacker with unauthorized access to any account, including administrative accounts.

REMEDIATION

Use parameterized queries / prepared statements for all database access, apply strict server-side input validation, and never construct SQL statements by concatenating user input.

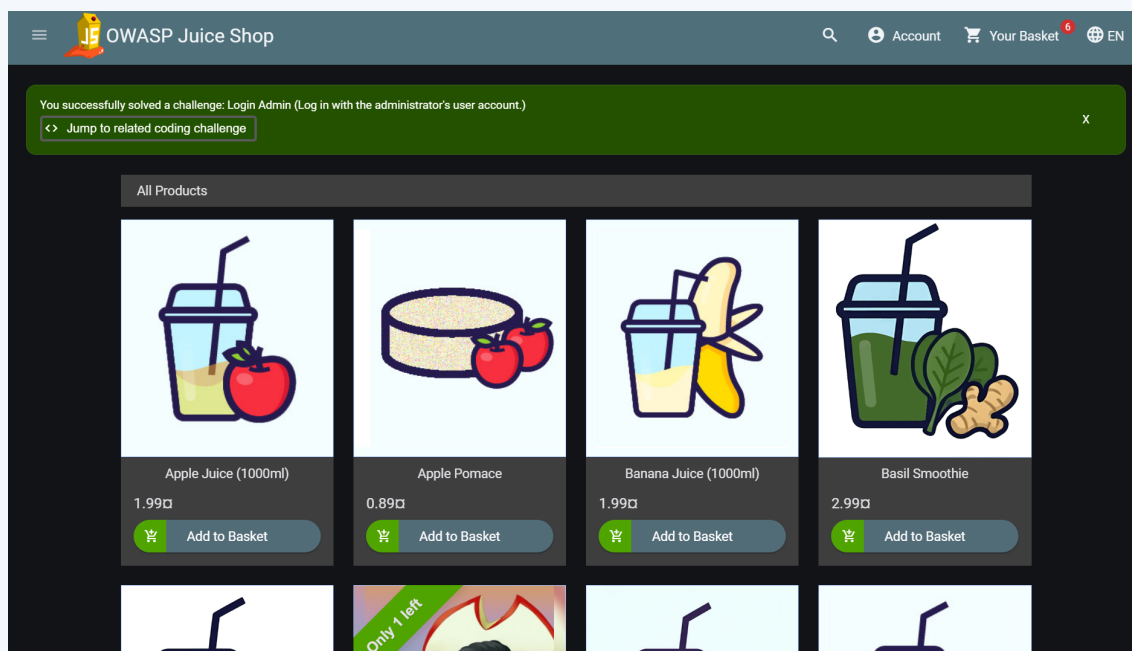


Figure 1 — Admin login bypassed via SQL injection payload; "Login Admin" challenge solved.

PT-02 — DOM-Based Cross-Site Scripting (XSS)

HIGH

CWE-79: Cross-Site Scripting

EXPLOITATION STEPS

A JavaScript-based XSS payload was submitted through the site search field. The browser executed the injected markup directly in the DOM, and the “DOM XSS” challenge was successfully solved.

```
<iframe src="javascript:alert(`xss`)">
```

IMPACT

DOM XSS allows attacker-controlled script execution inside a victim's browser under the application's own security context, enabling session/token theft, UI manipulation, and phishing.

REMEDIATION

Apply context-aware output encoding, avoid unsafe DOM sinks (e.g. innerHTML with raw input), validate and encode all untrusted input, and enforce a restrictive Content Security Policy.

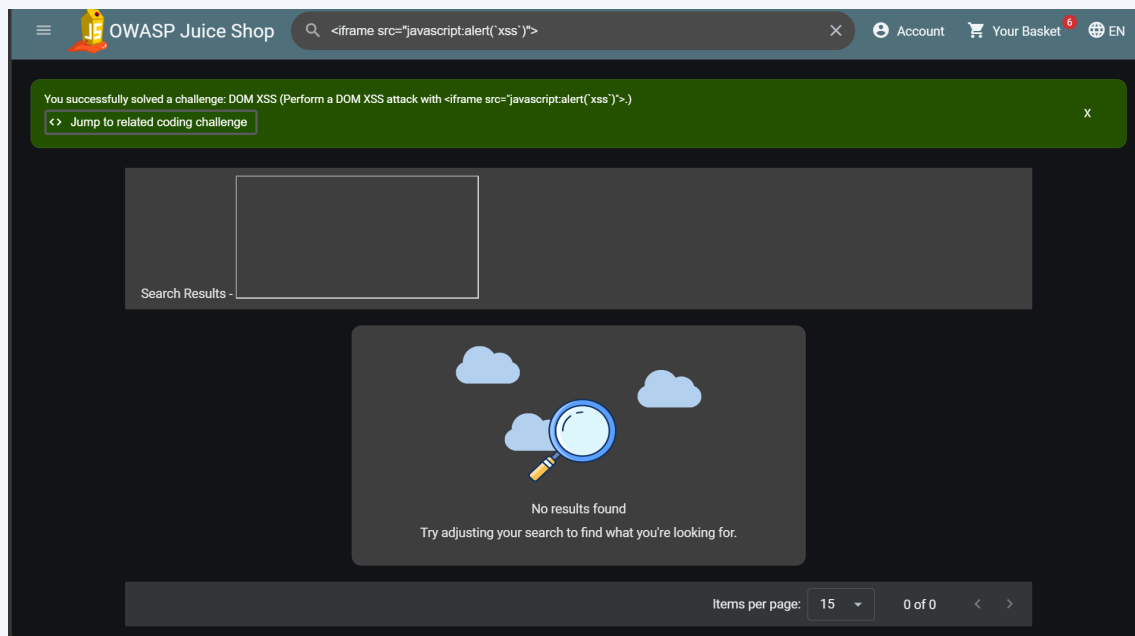


Figure 2 — DOM XSS payload executed via the search field; challenge solved with no results rendered.

PT-03 — Hidden Administration Panel Exposure

MEDIUM

CWE-284: Improper Access Control

EXPLOITATION STEPS

Gobuster was used for endpoint discovery against the target. The administration route was subsequently identified from the application's client-side JavaScript route information as `/administration`. Navigating directly to `http://localhost:3100/#/administration` displayed the Administration page and solved the “Admin Section” challenge.

IMPACT

Exposed administrative functionality becomes a serious security risk when server-side authorization is not enforced, as it allows unauthenticated or unauthorized users to reach sensitive user and feedback data.

REMEDIATION

Enforce authorization checks on the server for every administrative endpoint and operation; never rely on client-side route hiding as an access control mechanism.

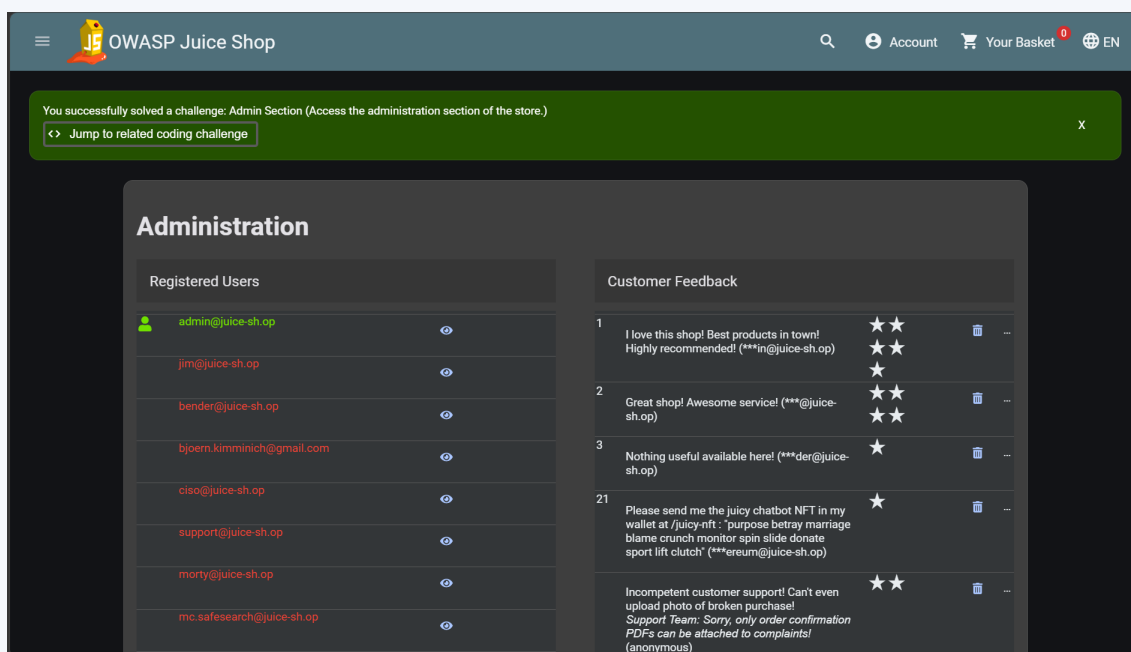


Figure 3 — Administration panel reachable directly, exposing registered users and customer feedback.

PT-04 — Burp Suite HTTP Request Interception

INFO

CWE-319: Cleartext Transmission (contributing factor)

EXPLOITATION STEPS

Burp Suite Proxy interception was enabled and traffic between the browser and the Juice Shop application was captured. The intercepted request was reviewed in the Proxy / Inspector view before being forwarded to the server.

IMPACT

Interception confirms that HTTP requests can be freely inspected and manipulated in transit within an authorized test environment, illustrating the risk unencrypted traffic poses in production.

REMEDIATION

Production applications should enforce HTTPS/TLS for all transport, use HSTS, and avoid exposing sensitive information in unencrypted HTTP traffic.

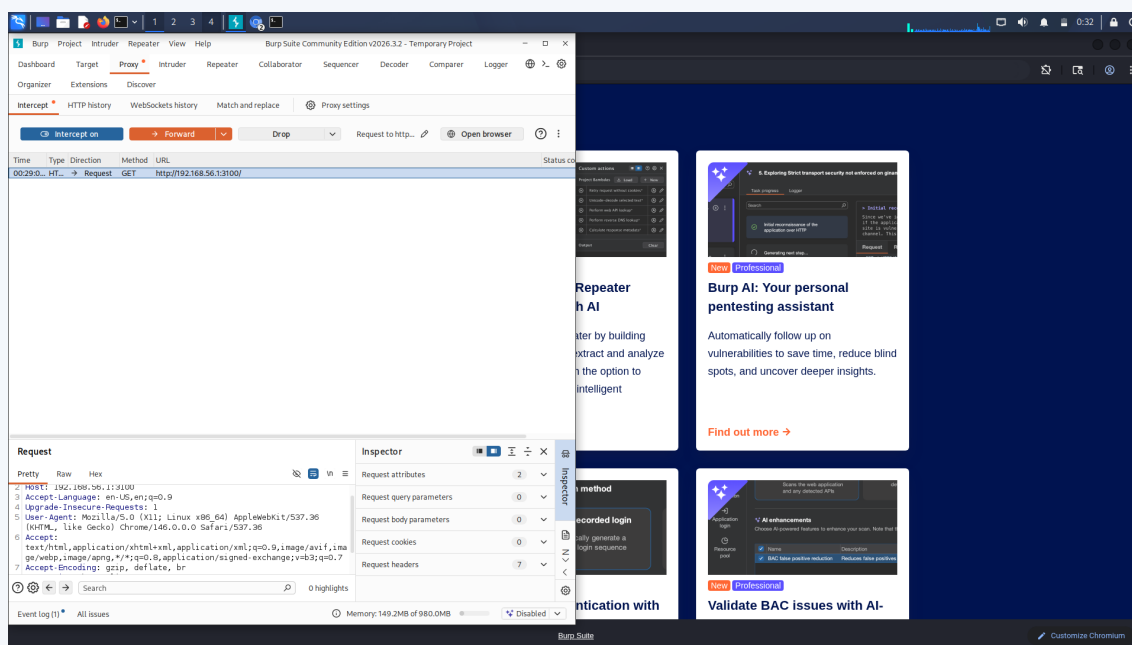


Figure 4 — HTTP GET request to the target intercepted and inspected in Burp Suite Proxy.

PT-05 — HTTP Parameter Modification

MEDIUM

CWE-20: Improper Input Validation

EXPLOITATION STEPS

A Juice Shop product-search request was intercepted in Burp Suite. The query parameter was modified to `q=test` and the altered request was forwarded to the server for processing.

`q=test`

IMPACT

Client-controlled parameters can be freely modified by an attacker; the resulting security impact depends entirely on the strength of server-side validation and authorization.

REMEDIATION

Validate all parameters server-side, enforce authorization independently of any client-supplied value, and never trust security-sensitive data originating from the client.

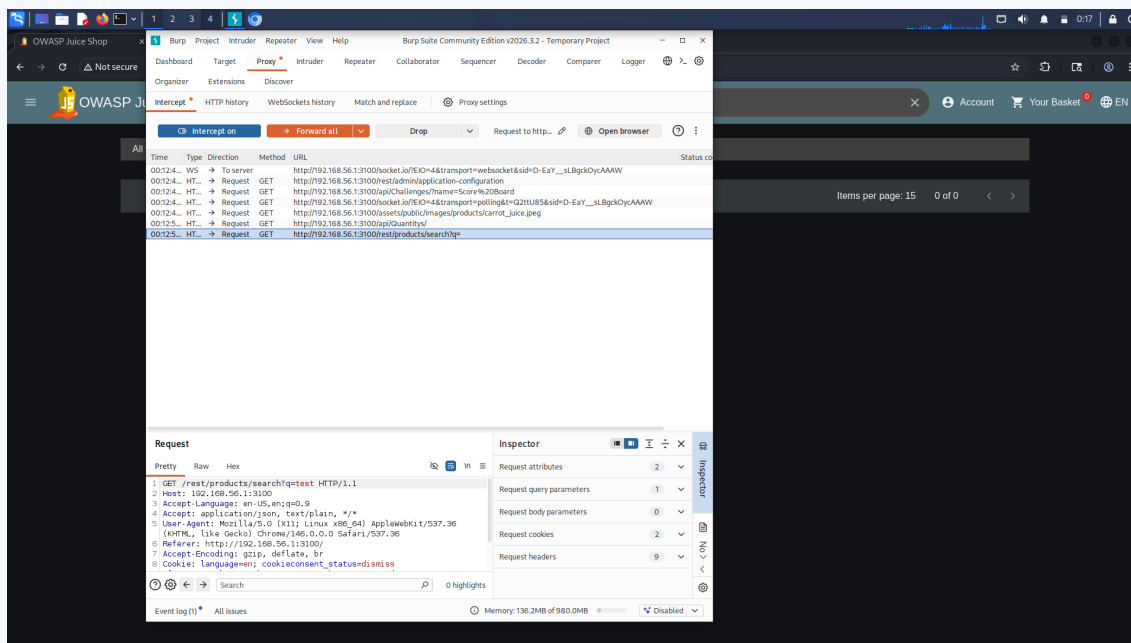


Figure 5 — Product-search request parameter modified in Burp Suite Repeater/Proxy before forwarding.

5. Directory Discovery / Tool Output

Gobuster directory discovery was performed against the local Juice Shop target. The scan identified endpoints including /api, /apis, /assets, /ftp, /media, /profile, /promotion, /rest, /robots.txt, and other application paths. A common 9393-byte response for nonexistent routes was excluded from the scan.

Tool output evidence: Gobuster-Output.txt

6. Evidence Files

File	Purpose
01-SQLi-Login-Bypass.png	SQL injection authentication-bypass evidence
02-XSS-DOM.png	DOM XSS challenge evidence
03-Hidden-Admin-Panel.png	Administration endpoint evidence
04-Burp-Intercept.png	Burp Suite interception evidence
05-Modified-Parameter.png	Modified request parameter evidence
Gobuster-Output.txt	Directory discovery tool output

7. Conclusion

The required exploitation and web application security testing exercises were completed in the local OWASP Juice Shop environment. Screenshots and tool output were collected as supporting evidence, and remediation guidance is included for each documented finding. Engagement scope was limited strictly to the authorized local training application; no external or production systems were tested.

Report prepared by: Nithin Vignesh

Engagement type: Authorized internal training exercise (Task 4)